ESCUELA SUPERIOR POLITÉCNICA DEL LITORAL

Facultad de Ingeniería en Electricidad y Computación

Ciberdefensa inteligente y adaptativa para la detección de amenazas y mitigación automática en redes programables mediante IA y SDN

PROYECTO INTEGRADOR

Previo la obtención del Título de:

Ingeniero en Telemática

Presentado por:

Nicole Fernanda Azú Perlaza

Oscar Tomás Muñoz Burgos

GUAYAQUIL - ECUADOR

Año: 2026

DEDICATORIA

Nicole Fernanda Azú Perlaza

A todas las personas que hicieron posible que este trabajo se llevara a cabo, especialmente a mi familia, por su apoyo incondicional durante todo el proceso académico.

Oscar Tomás Muñoz Burgos

Dedico este trabajo a mi familia y a todas las personas que me acompañaron en esta etapa, por su confianza y su apoyo constante.

AGRADECIMIENTOS

Nicole Fernanda Azú Perlaza

Agradezco al tutor PhD. Washington Adrián Velásquez Vargas por su guía y sus orientaciones durante todo el proyecto, así como a los docentes de la Facultad de Ingeniería en Electricidad y Computación por el sustento académico entregado.

Oscar Tomás Muñoz Burgos

Expreso mi agradecimiento al tutor de este proyecto y al equipo de la Facultad de Ingeniería en Electricidad y Computación de la ESPOL, por el apoyo técnico y los recursos que hicieron posible el desarrollo de esta solución.

DECLARACIÓN EXPRESA

Nosotros, Nicole Fernanda Azú Perlaza y Óscar Tomás Muñoz Burgos, acordamos y reconocemos que:

La titularidad de los derechos patrimoniales de autor (derechos de autor) del proyecto de graduación corresponderá al autor o autores, sin perjuicio de lo cual la ESPOL recibe en este acto una licencia gratuita de plazo indefinido para el uso no comercial y comercial de la obra con facultad de sublicenciar, incluyendo la autorización para su divulgación, así como para la creación y uso de obras derivadas. En el caso de usos comerciales se respetará el porcentaje de participación en beneficios que corresponda a favor del autor o autores.

La titularidad total y exclusiva sobre los derechos patrimoniales de patente de invención, modelo de utilidad, diseño industrial, secreto industrial, software o información no divulgada que corresponda o pueda corresponder respecto de cualquier investigación, desarrollo tecnológico o invención realizada por nosotros durante el desarrollo del proyecto de graduación, pertenecerán de forma total, exclusiva e indivisible a la ESPOL, sin perjuicio del porcentaje que nos corresponda de los beneficios económicos que la ESPOL reciba por la explotación de nuestra innovación, de ser el caso.

En los casos donde la Oficina de Transferencia de Resultados de Investigación (OTRI) de la ESPOL comunique los autores que existe una innovación potencialmente patentable sobre los resultados del proyecto de graduación, no se realizará publicación o divulgación alguna, sin la autorización expresa y previa de la ESPOL.

Guayaquil, 2 de octubre del 2026.

Nicole Fernanda Azú Perlaza	**Oscar Tomás Muñoz Burgos**
ESTUDIANTE ING. TELEMÁTICA	**ESTUDIANTE ING. TELEMÁTICA**

EVALUADORES

PhD. Rebeca Estrada
PROFESOR DE LA MATERIA

PhD. Washington Velásquez
PROFESOR TUTOR

RESUMEN

El crecimiento sostenido del tráfico digital y la sofisticación de los ataques cibernéticos han convertido a los centros de datos en objetivos prioritarios para los actores maliciosos, siendo el ransomware, la denegación de servicio distribuida y el movimiento lateral las técnicas de mayor impacto sobre la continuidad operativa de las instituciones de educación superior. El presente proyecto integrador propone el desarrollo de una plataforma de ciberseguridad que integra la detección de intrusiones basada en aprendizaje automático con la capacidad de respuesta automatizada sobre redes programables, articulando la detección de amenazas con la mitigación de las mismas en la misma plataforma. El sistema se desarrolló sobre una arquitectura de cuatro capas: percepción de tráfico en el borde de la red, análisis y clasificación de eventos mediante un modelo de aprendizaje automático basado en árboles de gradiente boosting, control de la infraestructura mediante un controlador de red programable y una capa de visualización web que centraliza la monitorización y la gestión de la información. Se implementó un entorno virtual de pruebas con tres hosts y un switch programable para la validación controlada de los flujos de ataque. Los resultados experimentales demostraron que la plataforma identifica y visualiza los eventos de seguridad en tiempo real y permite la mitigación de las conexiones maliciosas desde una interfaz única de administración, proporcionando una base sólida para su despliegue en el centro de datos de la FIEC.

Palabras Clave: Ciberseguridad, Redes Programables, Detección de Intrusiones, Inteligencia Artificial, Centro de Datos

ABSTRACT

The sustained growth of digital traffic and the increasing sophistication of cyberattacks have turned data centers into prime targets for malicious actors, with ransomware, distributed denial of service and lateral movement being the techniques that most severely affect the operational continuity of higher education institutions. This project develops a cybersecurity platform that integrates machine-learning-based intrusion detection with automated response over software-defined networks, articulating threat detection and mitigation within the same platform. The system was implemented on a four-layer architecture: traffic perception at the network edge, event analysis and classification through a gradient boosting decision tree model, infrastructure control through a programmable network controller, and a web visualization layer that centralizes monitoring and information management. A virtual test environment with three hosts and a programmable switch was used for controlled validation of attack flows. Experimental results showed that the platform identifies and visualizes security events in real time and allows malicious connections to be mitigated from a single administration interface, providing a solid foundation for its deployment at the FIEC data center.

Keywords: Cybersecurity, Software-Defined Networking, Intrusion Detection, Artificial Intelligence, Data Center

ÍNDICE GENERAL

RESUMEN i

ABSTRACT ii

ABREVIATURAS v

SIMBOLOGÍA vi

ÍNDICE DE FIGURAS vi

ÍNDICE DE TABLAS vii

1 INTRODUCCIÓN 1

1.1 Descripción del Problema 2

1.1.1 Visibilidad de la red 2

1.1.2 Detección y respuesta ante las amenazas 3

1.1.3 Gestión de activos y políticas de seguridad 3

1.2 Objetivos 4

1.2.1 Objetivo general 4

1.2.2 Objetivos específicos 4

1.3 Alcance y limitaciones 5

1.4 Marco teórico 6

1.4.1 Redes programables 6

1.4.2 Detección de intrusiones 7

1.4.3 Aprendizaje automático aplicado a la seguridad de las redes 7

1.4.4 Registro auditable de eventos de seguridad 8

1.5 Estado del arte 8

2 Metodología 11

2.1 Evaluación de Riesgos 12

2.2 Resultados 12
2.3 Conclusiones y Líneas Futuras 12

BIBLIOGRAFÍA **13**

APÉNDICES **14**

A Diagramas de configuración 15

ABREVIATURAS

API	Interfaz de Programación de Aplicaciones (Application Programming Interface)
CDoS	Denegación de Servicio Distribuida (Distributed Denial of Service)
DPI	Deep Packet Inspection (Inspección Profunda de Paquetes)
ESPOL	Escuela Superior Politécnica del Litoral
FIEC	Facultad de Ingeniería en Electricidad y Computación
IA	Inteligencia Artificial
IPS	Intrusion Prevention System (Sistema de Prevención de Intrusiones)
LXC	Contenedores de Linux (Linux Containers)
ML	Machine Learning (Aprendizaje Automático)
OVS	Open vSwitch
SDN	Software-Defined Networking (Redes Programables)
SVM	Máquina de Vectores de Soporte (Support Vector Machine)
VNX	Virtual Networks over LinuX

SIMBOLOGÍA

V Volumen de tráfico consumido por la red

T Tiempo de transacción de un evento de seguridad

f Frecuencia de muestreo de paquetes

p Probabilidad de detección de un ataque

ÍNDICE DE FIGURAS

1 Arquitectura general de la plataforma de ciberseguridad propuesta. 11

ÍNDICE DE TABLAS

1 Comparación de los enfoques revisados en el estado del arte 9

CAPÍTULO 1

1. INTRODUCCIÓN

La digitalización de los servicios académicos y administrativos ha convertido a los centros de datos institucionales en la infraestructura crítica sobre la que operan las plataformas de enseñanza, investigación y gestión administrativa. En este escenario, el Centro de Datos de la Facultad de Ingeniería en Electricidad y Computación (FIEC) de la Escuela Superior Politécnica del Litoral (ESPOL) concentra un volumen creciente de servicios digitales, lo que lo convierte en un objetivo recurrente para los actores maliciosos.

El impacto de las amenazas informáticas sobre este tipo de infraestructura no se limita a las pérdidas económicas. Una interrupción prolongada de los servicios afecta la continuidad académica, la disponibilidad de la información administrativa y la reputación institucional. Las técnicas de mayor incidencia en entornos educativos son la denegación de servicio distribuida (CDoS), el ransomware, el movimiento lateral y el abuso de credenciales National Institute of Standards and Technology, 2012.

Ante este panorama, los sistemas de detección de intrusiones basados en firmas, heredados de los sistemas IDS clásicos, resultan insuficientes: dependen de reglas estáticas que deben actualizarse manualmente, no escalan con la diversidad de amenazas contemporáneas y, al operar sobre tráfico cifrado, pierden visibilidad. Paralelamente, la monitorización aislada –donde el operador detecta la amenaza pero no puede actuar sobre ella– introduce un desfase que las brechas de seguridad explotan National Institute of Standards and Technology, 2024.

Las redes programables (Software-Defined Networking, SDN) aparecen como una alternativa que rompe esa separación entre detección y acción. Al separar el plano de control del plano de datos Kreutz et al., 2015, la lógica de la red se vuelve programable y centralizada, de modo que un evento de seguridad puede ser analizado por un modelo de aprendizaje automático y traducir su respuesta en una actualización de flujos sobre el

switch, de forma automática y en tiempo real Kim et al., 2015. Esta capacidad de cerrar el ciclo detección–mitigación es el eje del presente proyecto.

El presente documento se organiza en los siguientes capítulos: el Capítulo 1 presenta la introducción, la descripción del problema, los objetivos, el alcance, el marco teórico, el estado del arte y las contribuciones del proyecto. El Capítulo 2 desarrolla la metodología aplicada, la evaluación de riesgos y las alternativas tecnológicas consideradas. El Capítulo 3 presenta los resultados experimentales obtenidos en el escenario de pruebas. El Capítulo 4 expone las conclusiones y las líneas futuras de trabajo. Finalmente, se incluyen las referencias bibliográficas y los apéndices con el material complementario del proyecto.

1.1 Descripción del Problema

El Centro de Datos de la FIEC requiere una solución que sea capaz de visualizar, analizar y proteger la red en tiempo real. Sin embargo, las herramientas de seguridad actualmente disponibles en la institución presentan limitaciones que dificultan satisfacer este requerimiento. El análisis de la situación actual puede agruparse en tres ámbitos: la visibilidad sobre la red, la respuesta ante las amenazas y la gestión operativa de los activos y de las políticas.

1.1.1 Visibilidad de la red

En la actualidad, la observación del tráfico del Centro de Datos se apoya en herramientas generalizadas que no están integradas en una vista única. Los equipos de red gestionan sus propias tablas de reenvío, los servidores exponen sus registros de forma independiente y los cortafuegos reportan sus propios eventos; como consecuencia, el operador carece de una representación consolidada del estado de la red y de los eventos de seguridad que en él se producen. A ello se suma que el inventario de equipos no se encuentra centralizado en una herramienta de seguridad, de modo que la relación entre un evento de red y el activo afectado –con su área o departamento responsable, su segmento de red y su criticidad– debe resolverse de manera manual.

1.1.2 Detección y respuesta ante las amenazas

Los mecanismos de protección empleados hasta el momento se apoyan en reglas estáticas que no escalan con la diversidad de las amenazas contemporáneas y en procesos de mitigación que dependen de la disponibilidad del operador. En la práctica, esto implica que la mitigación de una conexión maliciosa se produce en el orden de los minutos, mientras que los tiempos de propagación de un ataque automatizado son del orden de los segundos. Además, no existe un canal formal de notificación hacia el equipo de soporte de TI, por lo que la detección de un evento no genera de manera automática un aviso al personal responsable, ni una recomendación sobre las acciones de prevención que deberían adoptarse para evitar la reaparición del ataque. El reporte de incidentes se realiza manualmente, con lo que se pierde trazabilidad y se dificulta el análisis posterior.

1.1.3 Gestión de activos y políticas de seguridad

El Centro de Datos no dispone de un módulo que permita registrar de forma estructurada los equipos nuevos que se instalan, ni de un mecanismo que permita incorporarlos masivamente a partir de los archivos de configuración que el Centro de Datos ya produce. Asimismo, las políticas de filtrado vigentes –las listas de servicios, dominios y puertos restringidos, y la segmentación por áreas– se aplican directamente sobre los equipos de red, sin una capa que las exprese como políticas de tráfico explícitas, auditables y gestionables desde la plataforma, lo que dificulta tanto su revisión como su actualización cuando la topología de la red cambia.

En conjunto, estas limitaciones se traducen en los siguientes vacíos operativos:

- La monitorización se realiza de forma fragmentada, sin una vista unificada del estado de la red ni de los eventos de seguridad.
- Los controles de mitigación existentes son manuales, lo que implica tiempos de respuesta directamente proporcionales a la disponibilidad del operador.
- No existe una capacidad de análisis automatizado que correlacione el tráfico observado con patrones de ataque conocidos o emergentes.
- No se dispone de un registro auditable e inalterable de los incidentes de seguridad atendidos.

- No existe un inventario estructurado de los equipos, por lo que el área o el departamento responsable de un activo no puede consultarse de forma inmediata.
- No existe un mecanismo que permita dar de alta nuevos equipos, ni importarlos masivamente desde los archivos de configuración del Centro de Datos.
- No existe un módulo de reglas de tráfico que permita expresar las políticas de filtrado por área, por equipo o por segmento, ni aplicar y auditar su estado.
- No existe un canal de notificación al equipo de soporte de TI, ni un mecanismo que recomiende acciones de prevención tras cada incidente.

El problema de investigación que aborda este proyecto es, en consecuencia, el siguiente: la necesidad es mejorar la detección y respuesta ante amenazas en redes programables. Se propone una plataforma que integre IA para detectar anomalías y SDN para mitigar automáticamente los ataques.

1.2 Objetivos

En esta sección se plantean los siguientes objetivos para guiar el desarrollo del proyecto.

1.2.1 Objetivo general

Desarrollar una plataforma de ciberdefensa inteligente y adaptativa para redes programables, mediante la integración de inteligencia artificial y redes definidas por software, para fortalecer la seguridad y continuidad de los servicios digitales.

1.2.2 Objetivos específicos

Estos son los objetivos específicos que guían el desarrollo del proyecto:

- Diseñar la arquitectura de la plataforma de ciberdefensa, mediante la definición de sus componentes y mecanismos de interacción, para integrar la detección de anomalías y la respuesta adaptativa en redes programables.

- Implementar un prototipo funcional de la plataforma, mediante la integración de modelos de inteligencia artificial, mecanismos de control SDN y registro de eventos, para detectar anomalías y mitigar automáticamente las amenazas identificadas.
- Evaluar el desempeño del prototipo, mediante experimentos controlados con tráfico legítimo y escenarios de ataque, para determinar la eficacia de la detección y mitigación y su impacto en el funcionamiento de la red.

1.3 Alcance y limitaciones

El alcance del proyecto comprende el desarrollo de un prototipo funcional de ciberdefensa adaptativa que integre IA para detectar anomalías, SDN para ejecutar acciones automáticas de mitigación y que permita registrar eventos de seguridad, acompañado de una evaluación experimental de su desempeño. El desarrollo se realizará y validará en un entorno virtual de pruebas, construido sobre un laboratorio de redes programables dentro del Centro de Datos de la FIEC.

El ámbito funcional del alcance comprende igualmente los módulos de operación acordados con el cliente: el inventario de activos con su configuración por área, departamento y segmento de red, la carga masiva de datos de equipos, el gestor de reglas de tráfico, el módulo de notificación al equipo de soporte de TI y el motor de recomendaciones post-incidente.

Las limitaciones del proyecto son las siguientes:

- El sistema se implementará dentro de la red de un laboratorio ubicado dentro del Centro de Datos de la FIEC, es decir, sobre una parte de la red y no sobre toda la red del centro de datos, por lo que su validación queda restringida a ese segmento.
- La aplicación de reglas de filtrado sobre tráfico productivo queda condicionada a la autorización previa y por escrito del cliente, conforme a los términos de la carta de compromiso.
- Quedan fuera del alcance la optimización del modelo de detección para tráfico cifrado, la integración con sistemas de gestión de eventos de seguridad corporativos de terceros, la administración de las políticas de filtrado ya instaladas en los equipos de red del Centro de Datos y la certificación formal del sistema conforme a marcos normativos externos.

1.4 Marco teórico

Esta sección tiene por propósito introducir los términos, los conceptos y las tecnologías que sustentan el desarrollo del proyecto, de manera que el lector disponga de las bases teóricas necesarias para comprender las decisiones de diseño adoptadas en los capítulos siguientes. Se abordan la arquitectura de las redes programables, los fundamentos de la detección de intrusiones y su evolución hacia los métodos basados en aprendizaje automático, las técnicas de aprendizaje automático aplicadas a la seguridad de las redes, y los mecanismos de registro auditable de los eventos de seguridad.

1.4.1 Redes programables

La arquitectura tradicional de las redes conmutadas se articula en dos planos claramente diferenciados: el plano de control, donde reside la lógica que decide el reenvío, y el plano de datos, donde se ejecutan las reglas de reenvío en cada dispositivo. Esta separación implica que cada protocolo, cada función y cada política de seguridad deba configurarse dispositivo por dispositivo, lo que produce tiempos de implementación altos, configuraciones heterogéneas y una visibilidad limitada sobre el estado global de la red.

La arquitectura de las redes programables propone invertir esta relación: el plano de control se centraliza en un componente software denominado controlador, y el plano de datos se limita a la ejecución de las reglas de flujo instaladas por este Kreutz et al., 2015. La comunicación entre ambos planos se establece mediante un protocolo estandarizado como OpenFlow, que define un conjunto común de primitivas Kim et al., 2015. En el presente proyecto el papel de controlador lo desempeña Ryu, y el de conmutador programable, Open vSwitch Pfaff et al., 2014, desplegado sobre máquinas virtuales de contenedor.

Para la seguridad de la red, la programabilidad aporta tres ventajas decisivas: la aplicación inmediata y centralizada de reglas de mitigación sin intervención manual por dispositivo; la observabilidad global de la topología y del estado de los flujos; y la trazabilidad de las decisiones, dado que toda acción ejecutada queda registrada en el controlador. Como contrapunto, el modelo introduce superficies de ataque adicionales: el controlador se convierte en un punto crítico cuya disponibilidad condiciona la de toda la red, la consistencia del estado entre control y datos debe garantizarse, y las capacidades

de la interfaz de programación deben limitarse conforme al principio de menor privilegio.

1.4.2 Detección de intrusiones

Un sistema de detección de intrusiones (IDS) analiza el tráfico con el propósito de identificar actividad maliciosa, mientras que un sistema de prevención de intrusiones (IPS) va más allý actúa bloqueando la conexión detectada National Institute of Standards and Technology, 2012. Ambos se apoyan en dos familias de técnicas: la detección por firmas, que compara el tráfico contra patrones de ataques conocidos, y la detección por anomalías, que construye un modelo del comportamiento normal y seãla como anómalo aquello que se aparta de él.

La detección por firmas ofrece baja tasa de falsos positivos y alta interpretabilidad, pero depende de la disponibilidad de la firma, lo que la vuelve inefectiva frente a ataques nuevos o polimórficos. La detección por anomalías, en cambio, permite identificar amenazas desconocidas, aunque trabaja sobre la asunción de que el comportamiento malicioso se aparta de la norma, por lo que puede ser desvirtuada por cambios legítimos en el tráfico y tiende a producir un mayor volumen de falsos positivos.

La evaluación de ambos enfoques se realiza mediante métricas de clasificación: precisión, exhaustividad (recall), valor F1 y área bajo la curva ROC. En el contexto de un centro de datos, la exhaustividad resulta crítica, pues un ataque no detectado se traduce en un incidente real, mientras que un falso positivo consume tiempo del equipo de soporte sin contribuir a la mitigación efectiva.

1.4.3 Aprendizaje automático aplicado a la seguridad de las redes

El aprendizaje automático permite derivar reglas de decisión a partir de ejemplos, en lugar de programarlas de forma explícita. En el contexto de la detección de intrusiones se emplea principalmente el aprendizaje supervisado, en el que cada flujo de red se etiqueta como benigno o malicioso y el modelo aprende la relación entre sus características y la etiqueta correspondiente.

Las técnicas de árboles de decisión son habituales en este ámbito por su interpretabilidad y su capacidad de modelar interacciones no lineales entre variables. El método de gradient boosting, que construye un conjunto de árboles de decisión

ajustados secuencialmente para corregir los errores de los anteriores, ha demostrado un rendimiento superior en problemas de detección de intrusiones con variables heterogéneas Ke et al., 2017. Esta familia de modelos es la que se emplea en la capa de análisis de la plataforma propuesta.

Dos características propias de este dominio condicionan el diseño del proceso de entrenamiento. La primera es el desbalance entre clases: en tráfico real, los ejemplos benignos son dos 'ordenes de magnitud mábundantes que los maliciosos, por lo que un modelo entrenado sin tratamiento específico tenderá a predecir siempre la clase mayoritaria. La segunda es el desajuste entre el entorno de entrenamiento y el de operación, conocido como deriva del concepto, que obliga a reentrenar o recalibrar el modelo conforme evoluciona el tráfico real del centro de datos.

1.4.4 Registro auditable de eventos de seguridad

El tratamiento de incidentes de seguridad exige, además de la detección y la mitigación, la posibilidad de reconstruir la secuencia de hechos posterior a un evento National Institute of Standards and Technology, 2012. Un registro de eventos debe ser útil, completo e inalterable: debe identificar el equipo afectado, la acción ejecutada y el responsable de la decisión, y debe resistir la manipulacińn deliberada de quien pudiera tener interés en ocultar la actividad.

Una solución común consiste en encadenar los registros mediante funciones hash, de modo que cada entrada incorporates el resumen de la anterior y cualquier alteración de una entrada previa invalidate las siguientes. Con la misma finalidade, las cadenas de bloques (*blockchain*) ofrecen un libro mayor distribuido y append-only, donde cada bloque incluye el hash del anterior y la escritura de un registro requiere la validación de los participantes Nakamoto, 2008. En el presente proyecto se emplea el registro auditable como mecanismo de respaldo de la información de eventos, de modo que la evidencia de lo ocurrido permanezca disponible para auditorías posteriores.

1.5 Estado del arte

El estado del arte agrupa los trabajos que han abordando la intersección entre la detección de intrusiones, la automatización de la respuesta y la programabilidad de la red. La Tabla

1 resume las familias de enfoques identificadas y sus principales limitaciónes.

Tabla 1: Comparación de los enfoques revisados en el estado del arte

Enfoque	**Detección**	**Respuesta**	**Limitación principal**
IDS/IPS por firmas	Firmas conocidas	Manual o por reglas	Cobertura limitada a ataques conocidos y actualización manual de reglas
Detección por anomalías con AA	Modelos de comportamiento	Alertas al operador	Elevada tasa de falsos positivos y ausencia de acción automática
Redes programables para la gestión	No aplica	Automatizada y centralizada	No aborda por sí solo la detección de amenazas
Integración IDS–SDN	Firmas y/o anomalías	Reglas de flujo sobre OpenFlow	Rara vez se valida en un despliegue real de centro de datos y no considera el inventario de activos
Registro auditable con blockchain	No aplica	No aplica	Costo computacional y de almacenamiento, y difusión lenta de la información
Trabajo propuesto	Aprendizaje automático	Reglas de flujo y notificaciń al equipo de soporte	Pendiente de validación en el entorno del cliente

Del análisis de la Tabla **1** se desprenden dos observaciones. La primera es que las técnicas que mejor resuelven la detección (aprendizaje automático) y las que mejor resuelven la respuesta (programabilidad de la red) han sido desarrolladas de forma prácticamente independiente, de modo que son escasas las soluciones integradas que permitan clasificar un evento y traducirlo a una acción concreta sobre la red dentro de una misma plataforma. La segunda es que la literatura revisada rara vez considera el ciclo operativo completo: el inventario de los activos del centro de datos, la gestión de políticas de filtrado por área o por equipo, la notificaciń al equipo de soporte y la entrega

de recomendaciones de mitigación tras el incidente.

El presente proyecto se sitúa en esa intersección. Su aportación consiste en integrar en una única plataforma la detección automatizada mediante aprendizaje automático, la mitigación automatizada mediante reglas de flujo sobre la red programable, el registro auditable de los eventos y un conjunto de funciones operativas orientadas al cliente –inventario de equipos, gestión de políticas de filtrado, notificación al equipo de soporte de TI y recomendaciones post-incidente– validadas sobre un escenario de pruebas controlado y destinadas a su despliegue en el Centro de Datos de la FIEC.

CAPÍTULO 2

2. Metodología

El proyecto aplica una investigación aplicada de carácter tecnológico, orientada a resolver un problema concreto del cliente mediante el desarrollo de un prototipo funcional. El proceso se estructura en cinco fases: (i) análisis del contexto y definición de requisitos funcionales y no funcionales; (ii) diseño de la arquitectura del sistema; (iii) implementación de cada módulo; (iv) validación experimental; y (v) despliegue y documentación.

La arquitectura propuesta es modular y se articula en cuatro capas, tal como se ilustra en la Figura **1**.

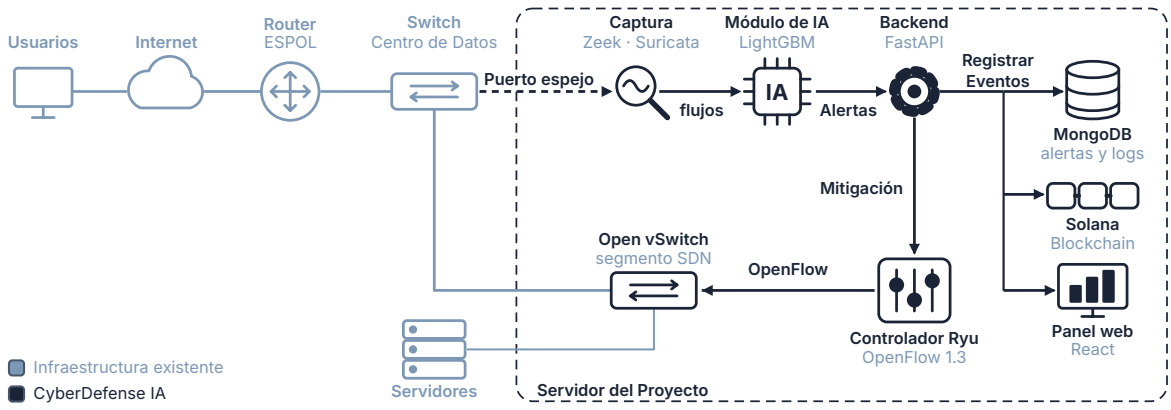


Figura 1: Arquitectura general de la plataforma de ciberseguridad propuesta.

Capa de percepción. Captura el tráfico de red mediante un puerto espejo (port mirroring) en el switch del Centro de Datos. El tráfico es analizado por herramientas de detección (Zeek y Suricata) que identifican actividades sospechosas y las envían al modelo de inteligencia artificial para su clasificación.

Capa de análisis. Procesa las características extraídas del tráfico mediante el modelo LightGBM para detectar anomalías y amenazas. Los eventos detectados se envían al backend (FastAPI) que los almacena en MongoDB junto con sus alertas y logs asociados.

Capa de control. El controlador Ryu, ejecutando OpenFlow 1.3, gestiona el switch virtual (Open vSwitch) del segmento SDN. Recibe instrucciones del backend para insertar, modificar o eliminar reglas de flujo dinámicamente, permitiendo la mitigación automática de amenazas detectadas.

Capa de presentación. Interfaz web desarrollada en React que centraliza la visualización del estado de la red, los eventos de seguridad y las acciones de mitigación ejecutadas. Incluye el tablero de monitoreo, el panel de administración y el acceso a los registros de eventos.

Capa de comunicación. Conecta los diferentes componentes mediante APIs REST y WebSockets. El backend expone endpoints para el frontend, el motor de IA y el controlador, permitiendo el intercambio de eventos de seguridad y comandos de mitigación en tiempo real.

La validación se realiza en un entorno virtual que reproduce la topología del escenario del cliente: tres máquinas virtuales con roles diferenciados (atacante, servidor de aplicación y servidor de datos) conectadas a un switch virtual programable, gobernado por un controlador de red. Sobre este escenario se reproducen técnicas de ataque de reconocimiento, fuerza bruta y denegación de servicio, midiendo la capacidad de detección, el tiempo de respuesta y la efectividad de la mitigación.

2.1 Evaluación de Riesgos

2.2 Resultados

2.3 Conclusiones y Líneas Futuras

BIBLIOGRAFÍA

Ke, G., Meng, Q., Finley, T., Wang, T., Chen, W., Ma, W., Ye, Q., & Liu, T.-Y. (2017). Lightgbm: A highly efficient gradient boosting decision tree. *Advances in Neural Information Processing Systems (NeurIPS)*, *30*, 3146–3154.

Kim, W., Hioroshi, H., Watabe, M., Bhamrakar, T., Jenkins, N., Mysore, S., Sridhar, V., Callaway, J., von Loring, G., & Martin, G. (2015). Onosr: An open-source production platform for enabling rapid development of sdn controllers. *ACM SIGCOMM Workshop on Emerging Technologies and Experimental Deployments (ICTEED)*, 1–6. https://doi.org/10.1145/2812746.2812751

Kreutz, D., Bhandari, M., Yang, X., Marchal, B., & Miorandi, D. (2015). Software-defined networks (sdn) layers and terminology (rfc 7426).

Nakamoto, S. (2008). Bitcoin: A peer-to-peer electronic cash system.

National Institute of Standards and Technology. (2012). *Computer security incident handling guide (nist special publication 800-61 rev. 2)* (tech. rep.). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r2

National Institute of Standards and Technology. (2024). *The nist cybersecurity framework (csf) 2.0* (tech. rep.). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.CSF.2.0

Pfaff, B., Pettit, J., Glance, B., & Phillips, M. (2014). The design and implementation of open vswitch. *USENIX NSDI*, 169–186. https://www.usenix.org/conference/nsdi14/technical-sessions/presentation/pfaff

APÉNDICES

A Diagramas de configuración

En esta sección se presenta nuevamente la arquitectura general de la plataforma, como se muestra en la Figura **1**:

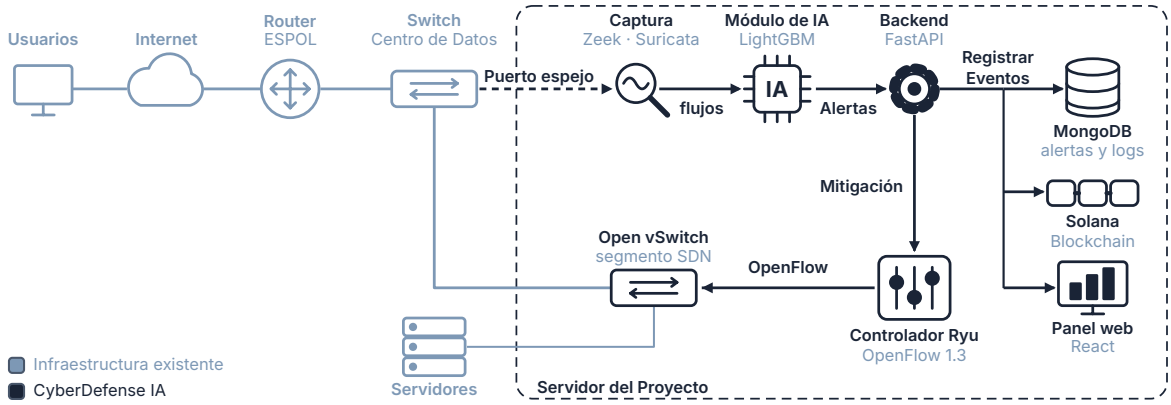


Figura 1: Arquitectura general de la plataforma de ciberseguridad propuesta.